

INDEPENDENT TECHNICAL RESEARCH

OmniRoute

What it is, how it works, what the free-token claim really means, and whether it is safe enough to use

BOTTOM LINE

A powerful personal lab gateway with real routing breadth, but a high-trust security and terms surface. Use it in an isolated, loopback-only pilot with official providers. Do not treat the defaults as production-safe.

RESEARCH WINDOW

20:31:06-20:41:10 IST
5 Aug 2026

SOURCE SNAPSHOT

commit 3022df5
branch release/v3.8.50

LATEST STABLE

v3.8.49
released 30 Jul 2026

Prepared as a decision report for a developer evaluating OmniRoute on an Ubuntu workstation.

SECTION 01

Executive assessment

The concise answer before the technical detail.

OmniRoute is a self-hosted AI gateway and dashboard. It exposes one OpenAI-compatible endpoint and translates, routes, retries and measures requests across a very large catalog of upstream services. It is not an AI model and it does not create official unlimited access to premium models. [\[1\]](#) [\[2\]](#) [\[4\]](#)

My assessment

Good for: controlled experimentation, learning multi-provider routing, testing fallback behavior, and using official API keys or local models on non-sensitive projects.
Not ready by default for: company source code, production CI, customer data, regulated data, or primary personal/paid accounts.

8/10	6/10	4/10	3/10
Routing breadth	Personal lab fit	Default safety	Sensitive production
Connector and protocol coverage	With isolation and hardening	Network/API defaults need work	High trust and ToS surface

Verdict	Promising and unusually feature-rich, but not set-and-forget infrastructure. Run a small, pinned, loopback-only pilot using one official provider or a local model. Expand only after you understand its egress, logs, costs and account terms.
---------	---

Why this conclusion

- The implementation breadth is real: the generated reference contains 290 provider categories, 19 routing strategies, protocol translation, fallback, quota/cost awareness, observability, MCP/A2A, memory and compression. [\[3\]](#) [\[4\]](#) [\[5\]](#)
- The security design includes meaningful controls, but the production/global CLI binds to 0.0.0.0 while the example environment leaves REQUIRE_API_KEY=false. On a LAN, that combination can expose paid inference unless the operator hardens it. [\[9\]](#) [\[24\]](#) [\[25\]](#)
- The headline free-token arithmetic matches the current source catalog, but the budget is concentrated, account-specific and not fungible. Some connectors are unofficial or terms-sensitive. [\[6\]](#) [\[7\]](#) [\[18\]](#) [\[19\]](#) [\[20\]](#)
- The project has strong supply-chain signals such as trusted publishing provenance, SBOM assets and extensive CI, while also shipping a very large native-binary package with a broad install-time and runtime attack surface. [\[12\]](#) [\[13\]](#) [\[14\]](#) [\[15\]](#) [\[28\]](#)

Decision in one line

Scenario	Recommendation	Reason
Learning / hobby routing	Proceed with guardrails	High feature value; low data sensitivity
Non-sensitive side project	Pilot first	Pin version, official providers, strict budgets
Work source / customer data	Do not use yet	Provider, logging, connector and privilege surface
Production shared gateway	No by default	Needs formal threat model, hardening and continuous review

SECTION 02

Research scope and reproducible snapshot

Evidence was checked against source code, not only the project landing page.

Research was performed for 10 minutes and 4 seconds of active inspection on 5 August 2026 (Asia/Kolkata). The repository was cloned at commit 3022df548e5fa688e0df82e8650fe847185708a4. Current web sources, release metadata, issue history, npm metadata and selected official provider terms were also reviewed.

What was examined

- README, architecture, security, routing, provider, free-tier, compression and compliance documentation.
- Current implementations for authentication guards, network binding, credential encryption, logging, Auto-Combo, no-auth providers, free-tier math and compression defaults.
- GitHub releases, repository issues #258 and #3134, repository advisories, npm package metadata, dependency audit output and publishing workflows.
- Official Kiro, Duck.ai, Gemini API, Mistral and OpenCode documentation or terms for claims that materially affect account safety or data handling.

Snapshot

Measure	Observed	Interpretation
Repository created	13 Feb 2026	Very young project at the snapshot date
GitHub adoption	40,398 stars; 5,335 forks	Strong attention, not a security guarantee
Open work	342 issues; 351 pull requests	High activity and review burden; counts move rapidly
Latest stable release	v3.8.49 - 30 Jul 2026	Use the release, not the 3.8.50 development branch
Current source version	3.8.50 at commit 3022df5	Default release branch was ahead of npm latest
License	MIT	Permissive; provided without warranty
Repository scale	10,676 tracked files	Large operational and review surface
JS/TS scale	398,453 lines	Static count across tracked JS/TS family files
Test/spec files	4,078 conventional filenames	Scale signal only; not a coverage or quality score
CI workflows	23	Includes CodeQL, Semgrep, Scorecard, DAST and resilience gates
Documentation files	1,452 under docs/	Broad documentation; some drift exists

Important limitation

This is a source-informed technical assessment, not an exhaustive line-by-line audit, penetration test, legal opinion or live provider-account test. No real credentials or sensitive prompts were sent through OmniRoute.

Measured facts can change after this snapshot. Free tiers, provider terms, model lists, security findings and release status should be re-checked before installation.[\[1\]](#) [\[14\]](#) [\[32\]](#)

SECTION 03

What OmniRoute is - and is not

A local control plane in front of upstream model services.

OmniRoute acts as an API gateway for AI traffic. A coding client sends a request to a local endpoint, commonly `http://localhost:20128/v1`. OmniRoute normalizes the request, chooses a provider/model, applies configured policies, forwards the prompt, normalizes the response and records operational data. [\[2\]](#) [\[4\]](#)

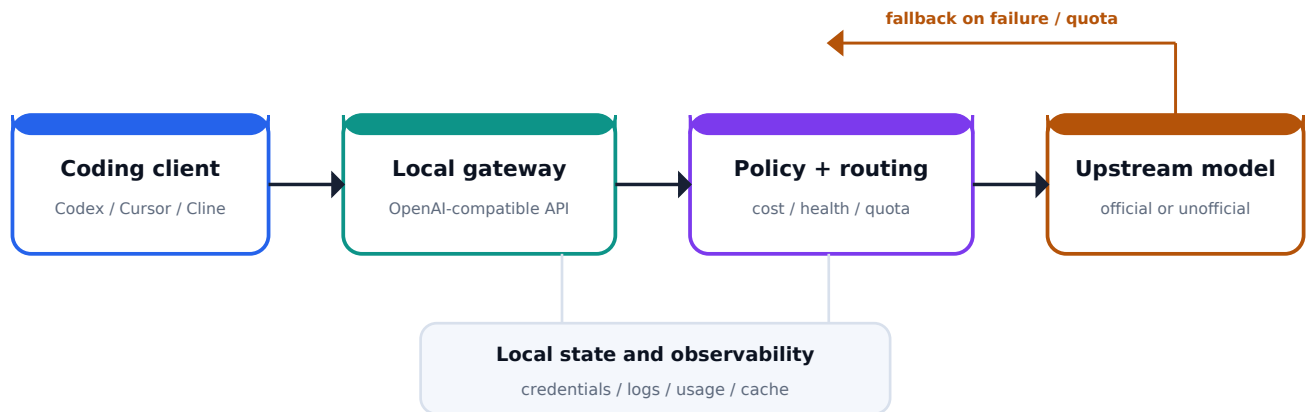


Figure 1. Simplified request path. The application can be local while inference remains remote; the selected upstream provider still receives the prompt.

What it provides

Layer	What OmniRoute does	What it does not guarantee
Compatibility	OpenAI, Anthropic, Gemini and Responses-style translation; streaming and media surfaces	Perfect parity for every provider-specific feature
Routing	Priority, cost, health, latency, quota, context and fallback strategies	A free or policy-compliant result unless configured and verified
Credentials	Stores API keys, OAuth tokens and optional web-session credentials	That provider accounts permit third-party proxy use
Observability	Usage, cost, quota, latency, call logs and audit surfaces	Privacy when request logging or upstream retention is enabled
Extensions	MCP, A2A, memory, plugins, traffic inspector, local launchers	A small or low-privilege runtime
Compression	Optional context and tool-output compaction engines	Lossless behavior for every engine or workload

What it is not

- It is not a model and does not perform remote inference itself unless you configure a local provider such as Ollama.
- It is not equivalent to OpenRouter or another upstream marketplace. It is software you operate, and many connectors talk directly to their respective services.
- It does not convert a ChatGPT, Claude, Kiro or other subscription into universally authorized API access. Permission depends on each provider's terms and supported client paths.
- Self-hosting the gateway does not automatically make prompts private. Privacy depends on the chosen provider, tier, logging configuration and optional cloud/extension features.

Trust boundary

The gateway sits directly in the path of source code, prompts, API keys, OAuth refresh tokens, cookies and model responses. Treat it like a credential broker and development proxy, not like an ordinary desktop utility.

SECTION 04

Provider and feature coverage

The 290-entry claim is supported by the generated reference, with important category differences.

Provider category	Count	Credential / route character
OAuth	23	Account authorization flows and subscription-linked access
Web cookie	31	Raw browser session cookie/token; frequently unofficial or experimental
API key	195	Official or compatible APIs, including paid and free-credit services
Local	12	Local inference or services operated by the user
Search	12	Search-specific upstreams
Audio-only	11	Speech, transcription or audio services
Upstream proxy	2	Another gateway as the upstream
Cloud agent	3	Hosted agent execution surfaces
System	1	System-level integration
Total	290	Generated reference total at commit 3022df5

The count is a connector inventory, not 290 interchangeable official LLM APIs. A provider entry can represent a web endpoint, local service, search or audio service, proxy, cloud agent or system route. [\[3\]](#)

Feature map

Area	Notable capabilities	Operational consequence
Routing	19 strategies; health, quota, cost and latency scoring; fallback and circuit breaking	Useful resilience, but policy defaults matter
Protocols	Chat Completions, Responses, Messages, embeddings, images, audio, rerank, search	Wide translation surface and compatibility burden
Clients	Codex, Claude Code, Cursor, Cline and other OpenAI-compatible tools	Centralizes configuration and credentials
Control plane	Web dashboard, CLI, REST API, remote CLI, webhooks	More management endpoints to secure
Agent systems	MCP server, A2A protocol, skills, memory and cloud agents	Some features can execute tools or spawn processes
Resilience	Key pools, quotas, cooldowns, retries, health checks, last-known-good	Can reduce downtime, also increases policy complexity
Compression	12-engine pipeline and per-combo profiles	Potential savings with fidelity trade-offs
Inspection	Traffic inspector, optional MITM, proxy and local service launchers	High-privilege features require strict isolation

The web-cookie category deserves special attention

The generated reference includes 31 connectors that ask the operator to paste a raw session cookie or token from a consumer web service. Such credentials can be more powerful than a narrow API key and may expose account history, billing or session access if mishandled. Several relevant paths are explicitly unofficial, experimental or reverse-engineered in source comments. [\[3\]](#) [\[26\]](#) [\[27\]](#)

Practical rule

Start only with a local model or one official API-key provider. Do not begin by importing browser cookies, OAuth refresh tokens or primary paid accounts into a six-month-old high-velocity gateway.

SECTION 05

Routing, fallback and cost behavior

Smart routing is useful, but several controls intentionally fail open.

Auto-Combo exposes names such as auto/coding, auto/fast, auto/cheap, auto/offline and auto/smart. The current documentation describes 19 overall routing strategies and a scoring model with 13 factors, including health, quota, blended cost, latency, task fit, stability, tier affinity, specificity, context affinity, connection density, cache affinity and reset-window affinity. [\[4\]](#) [\[5\]](#)

Critical behavior to understand

Behavior	What source/docs say	Safe interpretation
Category/tier filters	Fail open to the full connected pool if no candidate matches	A suffix such as :free is not a hard financial boundary by itself
auto/cheap	Chooses lowest estimated cost	Cheapest can still be paid
Budget cap default	Fallback policy is cheapest	Can select an over-cap candidate when all exceed the cap
Budget strict mode	Returns HTTP 402 instead of selecting over-cap	Use this when the cap must be real
Unpriced models	Cost visibility can be incomplete or fail open	Treat unknown price as unknown, not zero
Fallback	Retries another candidate after health/quota failure	The fallback provider may have different privacy and terms

Hard budget example

```
X-OmniRoute-Budget: 0.05
X-OmniRoute-Budget-Fallback: strict
```

The first header caps the estimated per-request USD cost. The second makes an over-budget request fail with HTTP 402. Without strict, the documented default is a soft fallback to the globally cheapest candidate even if it still exceeds the cap. [\[5\]](#)

Zero-configuration auto routing

At the inspected commit, the no-auth synthetic candidate allowlist contains only opencode and feLo-web. Both are marked tos: avoid in the project's own free-tier classification. Felo's implementation notes that it uses a reverse-engineered endpoint that may break. This is the mechanism behind a fresh-install path that can work without the user adding an API key; it is not official universal free access. [\[6\]](#) [\[26\]](#) [\[27\]](#)

Cost control

Use an explicit provider allowlist, a strict budget fallback, and a small per-key quota. Test what candidates remain after filters. Do not assume the word 'free' in a route name is a billing guarantee.

Recommended routing baseline

- One official provider connection or local model; no web-cookie or no-auth routes.
- Explicit allowlist for permitted providers and models.
- Strict per-request budget plus a conservative daily/monthly key quota.
- Fallback only among providers with compatible data handling and terms.
- Synthetic prompts first; inspect route/cost headers and logs before real code.

SECTION 06

The free-token claim: what the math says

The headline is reproducible from source, but it is an upper-bound aggregate rather than a single usable allowance.

The inspected catalog contains 522 model rows from 81 providers. Following the project's own pool-deduplication algorithm, the quantified steady recurring total is **1,526,225,000 tokens/month**. Adding 1,000,000 recurring credit-equivalent tokens and 625,500,000 one-time signup-credit tokens produces a first-month estimate of **2,152,725,000 tokens**. This supports the rounded README claims of about 1.53B steady and 2.15B first month. [\[2\]](#) [\[6\]](#) [\[7\]](#)

1.526B	1.0M	625.5M	2.153B
Steady recurring	Recurring credits	One-time credits	First month
Pool-deduped source total	Credit-equivalent estimate	Signup grants, first month	Steady + recurring + signup



Pool-deduped recurring token estimate per month

Figure 2. Concentration of the steady recurring estimate. Mistral alone contributes 65.5%; the top three pools contribute 85.2%.

Why 1.53B is not 1.53B interchangeable tokens

- Different models, context windows, request caps, regions, account tiers and output/input accounting are combined into one token-equivalent headline.
- Mistral contributes 1.0B of the 1.526B estimate. Official Mistral documentation says account limits are shown in AI Studio and vary by tier/account, so this should not be assumed for every user. [\[22\]](#)
- Daily caps are multiplied by 30. When a provider publishes only requests per day, the project estimates roughly 800 output tokens per request. These are modeling assumptions, not provider guarantees. [\[7\]](#)
- Uncapped but rate-limited free services are listed separately and deliberately excluded; multiplying rate limits continuously would create a misleading theoretical ceiling. [\[6\]](#) [\[7\]](#)
- Signup credits may require identity checks, deposits, region eligibility or expiry and do not recur.

Terms filter

Removing every row labeled avoid leaves 429 model rows, 66 providers and 30 quantified recurring pools. The steady estimate barely changes to 1,526,200,000 because most avoid-labeled no-auth/keyless rows have zero or unquantified token budgets. This does **not** make the remaining catalog automatically compliant; most rows are still labeled caution or ambiguous.

SECTION 07

Marketing claims versus current source

Several core counts hold up; other statements need qualification or are stale.

Claim	Finding	Assessment
290 providers	Generated reference sums to 290 across nine provider categories	Supported, with category caveat
43 free-tier pools	Current catalog computation identifies 43 quantified recurring pools	Supported
516 free models	Current source contains 522 rows	Stale in README
~1.53B tokens/month	Source computes 1,526,225,000	Arithmetic supported; availability not guaranteed
~2.15B first month	Source computes 2,152,725,000 including signup credits	Arithmetic supported; credits are conditional
Re-audited every two weeks	README says this; narrative doc still says researched 17 Jun while source says curated 22 Jul	Provenance inconsistent
Every request passes compression	Current runtime fallback config is enabled=false, defaultMode=off	Not true by default
15-95% compression	Docs scope it to eligible/tool-heavy sessions and many engines are lossy	Workload-dependent, not universal
\$0 to start	Possible through local/free/no-auth paths; zero-config no-auth allowlist is terms-sensitive	Technically possible, not equivalent to approved free access
Production-grade	Substantial controls and CI exist; defaults and high-privilege features still require hardening	A goal, not a conclusion

Source and documentation drift

- The free-tier narrative's contributor sentence still lists Groq at 117M and SambaNova at 30M, while its later table and the current catalog show 15M and 6M respectively. The current source also contains Nara at 150M, absent from that sentence. [\[6\]](#) [\[7\]](#)
- The README says 516 models, while the current catalog contains 522 rows. The rounded 1.53B and 2.15B totals nevertheless match the catalog computation. [\[2\]](#) [\[6\]](#)
- The free-tier document says its web research was conducted on 17 June 2026, while the data source declares a curated date of 22 July 2026. That can be legitimate incremental curation, but readers cannot trace every number to an equally fresh official source. [\[6\]](#) [\[7\]](#)
- The README's compression language implies transparent processing of every request, but current source defaults compression to disabled and off. [\[2\]](#) [\[11\]](#) [\[31\]](#)

Interpretation

The project is not simply fabricating its headline: the core free-tier total is computed and CI-gated. The risk is presentation. A defensible catalog estimate can still be mistaken for a guaranteed, compliant and homogeneous monthly allowance.

How to read future claims

Prefer	Be cautious with
Exact source constants and generated references	Hero graphics and rounded counts
Pool-deduped formulas with assumptions	Rate-limit x 24/7 theoretical ceilings
Official provider terms and account dashboards	Third-party summaries of what a subscription permits
Pinned release behavior	Default branch claims ahead of npm stable

SECTION 08

Terms-of-service and account risk

The main non-code risk is that technical connectivity does not equal provider authorization.



Source-catalog model rows (n=522); labels are the project's own classification.

Figure 3. The project's own labels for 522 catalog rows: 337 caution, 93 avoid, 38 ambiguous, 49 ok and 5 unknown. At the provider level: 43 caution, 15 avoid, 7 ambiguous, 14 ok and 2 unknown. [\[6\]](#) [\[7\]](#)

Provider examples checked against official sources

Provider / path	Official-source finding	Implication
Kiro subscription	Kiro permits its IDE, CLI, web, ACP-compatible IDEs and CI automation, but prohibits OpenClaw and similar third-party harnesses	Do not assume a subscription may be proxied through OmniRoute
Duck.ai	Terms prohibit automated querying, developing/offering AI services and circumventing limits	Automated proxy use creates a clear terms concern
Gemini unpaid quota	Google may use submitted content and outputs to improve products; human reviewers may process them; sensitive/confidential/personal data should not be sent	A free tier can carry a data-use cost
Gemini paid services	Prompts/responses are not used to improve products, subject to limited safety/security logging	Paid configuration has different privacy treatment
Mistral free mode	Limits are account/tier specific and visible in the admin console	The catalog's 1B estimate is not a universal entitlement
OpenCode Zen	Official flow uses an account and API key; paid/PAYG and free-model availability are documented	Differentiate official Zen API use from OmniRoute's no-auth opencode path

[\[18\]](#) [\[19\]](#) [\[20\]](#) [\[21\]](#) [\[22\]](#) [\[23\]](#)

Why web-cookie connectors are higher risk

- A raw browser session token may grant broader account access than a scoped API key and can be difficult to monitor or rotate safely.
- Consumer-web terms and anti-automation controls often differ from official API terms.
- Reverse-engineered endpoints can break without notice, trigger bot protection or expose unusual account behavior.
- Using a primary paid account can put unrelated history, billing, subscriptions and identity at risk.

Account rule

Use official API keys where possible. If you intentionally test an unofficial connector, use a separate low-value account with no personal history, no payment method and no reused password. Accept that the account may be limited or closed.

SECTION 09

Security model and unsafe defaults

There are real defensive controls, but the default exposure combination is the report's most important technical warning.

Security strengths visible in current source

Control	Current behavior	Assessment
Management authentication	Fresh dashboard settings default to require login; JWT/API-key/OAuth PKCE paths exist	Meaningful control when configured correctly
Route guard tiers	Spawn-capable routes are loopback-only; shutdown and database settings are always protected	Good defense-in-depth for high-risk endpoints
Credential encryption	AES-256-GCM when STORAGE_ENCRYPTION_KEY is set	Strong primitive; key lifecycle is operator-critical
Network protections	SSRF controls and fail-closed default CORS behavior	Useful but not a substitute for network isolation
Security automation	CodeQL, Semgrep, Scorecard, secret scanning/DAST-oriented workflows	Strong process signal, not proof of absence
Data controls	Retention settings, payload protection and per-key noLog	Useful after deliberate configuration

The risky default combination

```
HOST / hostname default: 0.0.0.0
REQUIRE_API_KEY=false
```

The production/global CLI serve path defaults to all network interfaces, and the example environment disables inference API-key enforcement. The dashboard's management login and the inference API are separate concerns. A workstation on a home, office, cloud or VPN network can therefore expose model invocation to other reachable hosts unless the operator binds to loopback and enables API-key enforcement. [\[17\]](#) [\[24\]](#) [\[25\]](#)

Default LAN exposure risk



High-privilege capabilities

The route-guard documentation classifies paths that can spawn subprocesses, run plugins, launch embedded services, change system proxy/DNS settings, start traffic inspection or MITM components, execute local launchers, run updates or open headful browser login flows. Many are loopback-only, which is positive; their existence still means the process should be treated as a high-trust local service. [\[9\]](#)

Minimum security posture

Bind only to 127.0.0.1, set REQUIRE_API_KEY=true, use strong independent secrets, keep the dashboard login enabled, do not tunnel the service, and avoid privileged extensions until the base gateway is understood.

SECTION 10

Historical findings and current status

Issue history shows both responsive fixes and an operationally dangerous default.

Issue #258 - substantive authentication findings were fixed

A March 2026 automated report alleged several vulnerabilities. One 'hardcoded password' finding was an obvious false positive caused by the command name omniroute-reset-password, illustrating that scanner severity labels need manual validation. The substantive findings were unprotected database backup import/export and Cursor/Kiro auto-import routes. The maintainer reported them fixed in PR #259. Current source was checked and each of those four routes now calls the shared authentication checks before performing the sensitive action. [\[16\]](#)

Historical path	Risk reported	Current-source verification
/api/db-backups/export	Download credential-bearing SQLite database	isAuthRequired + isAuthenticated guards present
/api/db-backups/import	Replace application database	isAuthRequired + isAuthenticated guards present
/api/oauth/cursor/auto-import	Read local Cursor tokens	Auth guards present; route also classified loopback-only
/api/oauth/kiro/auto-import	Read local AWS/Kiro SSO cache	Auth guards present

Issue #3134 - not an endpoint-specific bypass

A June 2026 report initially described /v1/messages as uniquely unauthenticated and later reported about USD 40 in unwanted usage. The maintainer's issue response explained that both the Anthropic-compatible and OpenAI-compatible inference endpoints are intentionally unauthenticated whenever REQUIRE_API_KEY=false, which is the default. That clarification means the core problem is operational exposure and default safety, not a single-route authentication bypass. [\[17\]](#) [\[24\]](#)

Lesson

A behavior can be 'by design' and still be unsafe in a common deployment. All-interface binding plus opt-in inference authentication is a configuration foot-gun, especially when paid upstream credentials are attached.

Current automated checks

- A lockfile-based npm audit returned zero known low, moderate, high or critical advisories at the research snapshot. This is a point-in-time dependency-advisory check, not a source audit.
- The public GitHub repository advisory API returned no published repository security advisories. Absence of advisories is not evidence that no vulnerabilities exist. [\[30\]](#)
- The repository includes 23 workflows, with CodeQL, Semgrep, Scorecard, DAST smoke, nightly LLM-security and resilience/property/mutation-style gates among them. [\[28\]](#)

Overall security interpretation: responsive development and multiple defenses are positive. The large codebase, very young age, credential-broker role, native dependencies and high-privilege features keep residual risk substantial.

SECTION 11

Data handling, logs and credential storage

Local control plane does not mean local data processing.

Where data can go

Data	Local handling	Potential external recipient
Prompt / source code	Parsed, routed, optionally transformed and logged	Selected model provider; optional proxy or cloud feature
Model response	Normalized, streamed, measured and potentially logged	Client; local storage; optional observability integration
API keys / OAuth tokens	Stored in local database; encrypted only with storage key	Provider authentication endpoint; optional secret sync if explicitly enabled
Web cookies	Stored as high-value provider credentials	Consumer web service and any configured proxy path
Usage / cost / latency	Dashboard and database telemetry	Local by default; possible configured cloud/observability target

Credential encryption

With STORAGE_ENCRYPTION_KEY, current code uses AES-256-GCM. Without the key, diagnostic code describes a plaintext passthrough mode. The global CLI can generate and persist a key on first run when no database exists; custom source/Docker deployments must ensure the key is explicitly set, protected and backed up. Losing it can make encrypted credentials inaccessible. [\[8\]](#) [\[24\]](#)

Logs and retention

Application and call/request retention defaults are generally seven days, with row and artifact caps. A per-API-key noLog flag suppresses request payload logging in call-log paths, but should not be interpreted as disabling all administrative, MCP or operational audit data. Verify the effective setting and inspect the database/log directories with synthetic data. [\[10\]](#)

Cloud and update behavior

- The default cloud URL is empty and cloud sync is opt-in. Secret overwrite/sync is separately gated by OMNIROUTE_CLOUD_SYNC_SECRETS=true.
- The CLI update notifier checks npm approximately once per 24 hours unless OMNIROUTE_NO_UPDATE_NOTIFIER is set.
- No evidence of mandatory external product analytics was identified in this targeted review. Internal request telemetry and optional external integrations do exist. This was not an exhaustive egress audit.

Data suitability

Data class	Recommendation
Synthetic prompts / public code	Acceptable for an isolated pilot
Personal side-project code	Only with official providers and verified logging/privacy
Company code / credentials	Do not use without employer approval and formal review
Customer, regulated or highly confidential data	Do not route through this evaluation setup
Primary consumer-web sessions	Do not import; use separate low-value test accounts if intentionally testing

Privacy rule	If the selected upstream is remote, that provider receives the prompt. To keep inference local, configure and verify a local model path; running only the gateway on your machine is not enough.
--------------	--

SECTION 12

Compression: useful, optional and sometimes lossy

The current default is off, despite stronger marketing language in the README.

Current source fallback settings are enabled: false, defaultMode: off and autoTriggerTokens: 0. Therefore, the README statement that every request passes through the compression pipeline should not be read as the fresh-install default. [\[2\]](#) [\[11\]](#) [\[31\]](#)

Engine risk map

Engine / class	Character	Recommended use
Lite	Lossless cleanup; catalog estimates about 15% savings	Safest first experiment; still validate exact payload behavior
Session dedup / CCR	Cross-turn dedup or recoverable references	Useful when retrieval path is reliable
Headroom / structured compaction	Lossless or reconstructable for supported structures	Good for repetitive JSON/tool data
RTK	Lossy truncation/compaction of command and tool output	Routine noisy logs; avoid when every line matters
Caveman	Rule-based prose rewrite; lossy	Low-stakes prose; not exact instructions or legal/security text
Aggressive	Summarizes or ages earlier context irreversibly	Only after workload-specific fidelity tests
LLMLingua-2	Semantic token pruning using optional local model	Experimental; validate code and factual retention
Ultra	Heuristic pruning, code thinning and truncation; high loss risk	Last resort, not code review/debug/security work
OmniGlyph	Experimental context-as-image path	Avoid for compatibility-critical workflows

How to interpret 15-95%

The project scopes its large savings to eligible and tool-heavy sessions, especially stacked RTK/Caveman paths. Savings depend on how repetitive/noisy the context is and on which engines actually run. Higher compression can save tokens while removing the exact error, code line, ordering or historical detail an agent needs. [\[2\]](#) [\[31\]](#)

Safe adoption sequence

- 1 Leave compression off for the baseline and record task success, cost and token counts.
- 2 Enable Lite only on synthetic and non-sensitive workloads.
- 3 Diff the exact upstream request or use the project's preview/eval tools where available.
- 4 Test failures, stack traces, patches, JSON, long conversations and tool-call ordering.
- 5 Add one lossy engine at a time only if measured task quality remains acceptable.
- 6 Keep aggressive, Ultra and semantic pruning off for migrations, security review, production debugging and exact code transformations.

Default recommendation

For a first pilot: compression off. If cost pressure justifies testing, use Lite first. Token savings are secondary to preserving the evidence an agent needs to make a correct change.

SECTION 13

Supply chain, package footprint and maturity

Strong publishing controls coexist with a very large native-binary distribution.

Measured package and dependency surface

830.8 MB Unpacked npm size About 792.3 MiB	21,765 Package files npm package metadata	878 Production nodes Current lockfile audit graph	1 npm maintainer Listed for v3.8.49
---	--	--	--

The root package declares 74 direct dependencies, 8 optional dependencies, 50 development dependencies and 165 npm scripts. A lockfile-based audit traversed 878 production and 2,599 total dependency nodes. These numbers include transitive packages and should be treated as attack-surface indicators, not defects. [\[12\]](#) [\[15\]](#)

Install-time behavior

The global npm install runs a postinstall script. The install/runtime code handles native components such as better-sqlite3, wreq-js and tls-client-node; depending on platform and availability it may copy, download, rebuild or reinstall binaries. The runtime can also lazily install certain components. This increases supply-chain and privilege exposure compared with a small pure-JavaScript client. [\[12\]](#) [\[13\]](#)

Positive trust signals

- npm v3.8.49 is published through GitHub Actions as a trusted publisher with a signed provenance attestation. [\[14\]](#) [\[15\]](#)
- The release workflow creates a CycloneDX npm SBOM, and Docker workflows also generate image SBOM material. [\[14\]](#) [\[28\]](#)
- The latest release commit is signed/verified on GitHub, and the project maintains multiple security/quality workflows. [\[14\]](#) [\[28\]](#)
- The project is MIT licensed and source-visible. [\[29\]](#)

Maturity cautions

- The repository was only about six months old at the snapshot, yet already had a very large code and provider surface.
- Release v3.8.48 notes say v3.8.47's npm package crashed on every boot because a required artifact was omitted; v3.8.48 was the installable hotfix. This is evidence of rapid correction and release-process fragility. [\[14\]](#)
- One listed npm maintainer is a continuity and account-compromise concentration risk, even if GitHub contributors are broader. [\[15\]](#)
- A huge package, native postinstall logic, embedded services, plugins, browser automation and MITM features create a much wider threat model than the simple 'one endpoint' pitch suggests.

Install rule

Prefer a clean VM or container. Pin a released version or image digest; do not use latest or the active 3.8.50 branch for a normal pilot. Verify the release tag, provenance and SBOM before upgrading.

SECTION 14

A safer Ubuntu evaluation plan

A reversible pilot that avoids primary accounts, sensitive data and accidental network exposure.

Recommended starting posture

- 1 Use a disposable VM or isolated container host, not the workstation environment that holds work credentials.
- 2 Pin the latest stable release (v3.8.49 at this snapshot) or a verified container digest. Do not track latest automatically.
- 3 Publish the service only on 127.0.0.1:20128. Confirm with `ss -ltnp` that no all-interface listener exists.
- 4 Set `REQUIRE_API_KEY=true`. Keep dashboard login required. Generate independent high-entropy values for JWT, API-key and storage-encryption secrets.
- 5 Begin with local Ollama or one official API-key provider. Do not add OAuth subscriptions, no-auth routes or browser cookies.
- 6 Use a provider/model allowlist, strict per-request budget fallback and a small daily/monthly quota.
- 7 Create a no-log API key for test requests, then confirm effective database/log behavior with synthetic prompts.
- 8 Leave cloud sync, plugins, tunnels, traffic inspection, MITM, embedded services, local launchers and compression disabled.
- 9 Test with a synthetic repository. Observe which upstream receives each request, request/cost headers, fallback paths and outbound destinations.
- 10 Back up the data directory and `STORAGE_ENCRYPTION_KEY` together in protected storage. If the pilot ends, revoke provider keys and remove the isolated environment.

Environment/security checklist

```
REQUIRE_API_KEY=true
HOST=127.0.0.1
JWT_SECRET=<independent random secret>
API_KEY_SECRET=<independent random secret>
STORAGE_ENCRYPTION_KEY=<independent random secret; back it up>
OMNIROUTE_CLOUD_SYNC_SECRETS=false
OMNIROUTE_NO_UPDATE_NOTIFIER=1
```

Exact variable support and deployment precedence should be checked against the pinned release. For local plain HTTP only, a `secure-cookie` flag may need to remain false; any remote deployment requires TLS and a fresh threat model. [\[24\]](#) [\[25\]](#)

Pilot acceptance gates

Gate	Pass condition
Exposure	Only 127.0.0.1 listener; requests without valid key fail
Routing	Only explicitly approved providers/models are selected, including fallback
Budget	Over-cap test fails with HTTP 402; no silent paid fallback
Privacy	No sensitive payload in retained logs; upstream terms/data use are acceptable
Credentials	Encrypted at rest; key backup and revocation plan tested
Quality	Baseline tasks succeed without compression; failure modes are understood
Updates	Manual pinned upgrade, verified provenance/SBOM, rollback path

Stop condition

If you cannot prove the listener is local-only, authentication is enforced, the provider set is constrained and costs are capped strictly, do not attach a paid account or real repository.

SECTION 15

Decision matrix and final verdict

Match the deployment to the sensitivity of the work.

Use case	Fit	Conditions
Learn LLM gateway concepts	Good	Synthetic prompts; isolated host
Compare official free/paid APIs	Good with care	Official keys; strict budget; verify terms
Route to local Ollama	Good	Confirm no remote fallback and no external egress
Personal non-sensitive coding	Conditional	Pinned release; loopback; allowlist; no cookies
Use primary ChatGPT/Claude/Kiro account	Poor	Subscription permission and account risk are unclear or restrictive
Company source code	Poor	Requires employer approval, security review and DPA-compatible providers
Shared team/production gateway	Poor by default	Needs formal operations, threat model, TLS, auth, monitoring and patch process
Customer/regulated data	Do not use for this pilot	Data-handling and provider obligations require dedicated review

Frequently asked questions

Is OmniRoute malware?

No evidence of malware was identified. It is open-source MIT software with signed releases, provenance and security automation. It is still a credential broker with native binaries and high-privilege optional features, so 'not malware' is not the same as 'safe for all data.'

Does it provide unlimited free Claude, GPT or Gemini?

No. It aggregates provider free tiers, signup credits, local/no-auth paths and optional unofficial connectors. Limits, model quality, eligibility, privacy and terms differ. The current 1.53B estimate is dominated by a few pools and is not a single official allowance.

Is it private because it runs locally?

Only the gateway is local. A remote provider still receives the prompt. Local inference requires a verified local model route with no remote fallback.

Should I install it?

Yes only as an isolated, reversible lab pilot if the routing features are valuable to you. No for sensitive work or primary accounts until you have hardened, measured and approved the full path.

Final verdict

Proceed experimentally, not operationally. OmniRoute is an ambitious and technically substantive gateway. The most valuable capabilities - compatibility translation, health/cost/quota routing and centralized observability - are genuine. The main risks are equally genuine: unsafe inference exposure if defaults are accepted, unofficial and terms-sensitive account paths, remote-provider data use, credential concentration, lossy transformations and a very large fast-moving supply chain.

Recommended decision

Run a two-stage pilot: first local Ollama, then one official API-key provider. Keep it loopback-only, authenticated, pinned, compression-off and strictly budgeted. If that does not produce clear value, stop; there is no reason to absorb the account and security risk merely to chase a headline token number.

SECTION A

Appendix: measured findings at a glance

Static measurements from the inspected commit and current package metadata.

Free catalog

Metric	All rows	Excluding project's 'avoid' label
Model rows	522	429
Providers represented	81	66
Quantified recurring pools	43	30
Steady recurring tokens	1,526,225,000	1,526,200,000
Recurring credit tokens	1,000,000	1,000,000
One-time signup tokens	625,500,000	614,500,000
First-month total	2,152,725,000	2,141,700,000
Rows marked trainsOnPrompts	13	Source flag, not an exhaustive privacy map

Catalog free-type counts

Type	Rows	Treatment in headline
Recurring daily	146	Monthly tokens pool-deduped
Recurring monthly	64	Monthly tokens pool-deduped
Keyless	122	Included only when quantified; often zero
Recurring uncapped	68	Listed but not summed
Recurring credit	5	Added separately
One-time initial	110	First-month only, pool-deduped
Discontinued	7	Not recurring

Top recurring pools

Pool	Tokens/month	Project ToS label
Mistral	1,000,000,000	caution
LLM7	150,000,000	caution
Nara	150,000,000	caution
Gemini	60,000,000	caution
Cerebras	30,000,000	caution
Cloudflare AI	30,000,000	caution
API-Airforce	24,000,000	caution
Ollama Cloud	20,000,000	ambiguous
GitHub Models	18,000,000	caution
Groq	15,000,000	caution

Method note: free-tier rows were parsed from freeModelCatalog.data.ts and aggregated with the max-per-pool logic documented in freeModelCatalog.ts. Counts do not validate every upstream quota. [\[6\]](#) [\[7\]](#)

SECTION R

References

Primary repository sources and official provider materials used in this report.

Repository sources are pinned to commit 3022df5 where practical. Web terms and release pages were checked on 5 August 2026. All links are clickable.

- [1] **Repository snapshot at commit 3022df5.**
<https://github.com/diegosouzapw/OmniRoute/tree/3022df548e5fa688e0df82e8650fe847185708a4>
- [2] **README and project claims.**
<https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/README.md>
- [3] **Generated provider reference.** https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/docs/reference/PROVIDER_REFERENCE.md
- [4] **Architecture documentation.**
<https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/docs/architecture/ARCHITECTURE.md>
- [5] **Auto-Combo routing documentation.**
<https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/docs/routing/AUTO-COMBO.md>
- [6] **Free-model catalog data.** <https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/open-ss/e/config/freeModelCatalog.data.ts>
- [7] **Free-tier methodology and caveats.**
https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/docs/reference/FREE_TIERS.md
- [8] **Project security policy.**
<https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/SECURITY.md>
- [9] **Route guard security tiers.**
https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/docs/security/ROUTE_GUARD_TIERS.md
- [10] **Compliance, logging and retention.**
<https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/docs/security/COMPLIANCE.md>
- [11] **Compression engine catalog source.** <https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/open-sse/services/compression/engineCatalog.ts>
- [12] **Package metadata and dependency declarations.**
<https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/package.json>
- [13] **Install-time native binary logic.**
<https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/scripts/build/postinstall.mjs>
- [14] **Latest stable GitHub release v3.8.49.** <https://github.com/diegosouzapw/OmniRoute/releases/tag/v3.8.49>
- [15] **npm package omniroute v3.8.49.** <https://www.npmjs.com/package/omniroute/v/3.8.49>
- [16] **Historical vulnerability report issue #258.** <https://github.com/diegosouzapw/OmniRoute/issues/258>
- [17] **Authentication/default exposure issue #3134.** <https://github.com/diegosouzapw/OmniRoute/issues/3134>

SECTION R

References - continued

- [18] Kiro official FAQ. <https://kiro.dev/faq/>
- [19] Duck.ai privacy policy and terms. <https://duckduckgo.com/duckai/privacy-terms>
- [20] Gemini API additional terms. <https://ai.google.dev/gemini-api/terms>
- [21] Gemini API rate limits. <https://ai.google.dev/gemini-api/docs/rate-limits>
- [22] Mistral usage limits documentation. <https://docs.mistral.ai/admin/billing-usage/usage-limits>
- [23] OpenCode Zen documentation. <https://opencode.ai/docs/zen/>
- [24] Default environment template.
<https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/.env.example>
- [25] CLI serve network binding.
<https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/bin/cli/commands/serve.mjs>
- [26] No-auth Auto-Combo virtual factory. <https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/open-sse/services/autoCombo/virtualFactory.ts>
- [27] Felo provider implementation. <https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/open-sse/config/providers/registry/felo-web/index.ts>
- [28] CI workflows directory.
<https://github.com/diegosouzapw/OmniRoute/tree/3022df548e5fa688e0df82e8650fe847185708a4/.github/workflows>
- [29] MIT license. <https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/LICENSE>
- [30] GitHub repository security overview. <https://github.com/diegosouzapw/OmniRoute/security>
- [31] Compression guide. https://github.com/diegosouzapw/OmniRoute/blob/3022df548e5fa688e0df82e8650fe847185708a4/docs/compression/COMPRESSION_ENGINES.md
- [32] Current release list. <https://github.com/diegosouzapw/OmniRoute/releases>

Reading note

Provider terms and limits can change without a repository release. Before connecting an account, open the official provider link, check your account tier and confirm that use through a third-party gateway is permitted.

End of report

OmniRoute independent research snapshot - 5 August 2026